

# QA Report: Payments API

**Report ID:** QA-PEG-004 | **Date:** 2026-04-09 | **Sprint:** Sprint 3 **Service:** Ubn-Payments-API | **Environment:** Development (dev-api.onecluster.co)

## Executive Summary

The Payments API provides fund transfer, transaction status inquiry, and name enquiry capabilities for the Pegasus BaaS platform. All payment endpoints require both HMAC-SHA256 request signing and mTLS client certificate authentication. QA testing was **blocked** on all payment endpoints because the sandbox environment enforces mTLS validation but no sandbox client certificate has been provisioned for QA. This report documents the blocking issue and findings from code review.

## Scope

- POST /api/v1/payments/transfer — Fund transfer (intrabank and interbank via MiServe)
- GET /api/v1/payments/{ref}/status — Transaction status inquiry
- POST /api/v1/payments/account-enquiry — Name enquiry (bank account validation)
- POST /api/v1/payments/bulk-transfer — Bulk fund transfer (new feature)
- HMAC-SHA256 signature requirement on all endpoints
- mTLS client certificate authentication
- MiServe response code mapping (35 codes)
- Error handling and idempotency

## Changes This Sprint (Mar 31 — Apr 9)

- 15 commits to Ubn-Payments-API
- Lekan added name enquiry endpoint (POST /api/v1/payments/account-enquiry)
- Lekan added bulk transfer feature (POST /api/v1/payments/bulk-transfer)
- MiServe response code mapping expanded to 35 codes
- CI/CD pipeline configuration
- Idempotency key enforcement on transfer endpoints
- Transaction audit logging improvements
- Webhook notification on transfer completion

## Test Results

### Fund Transfer

| Test ID    | Test Case                               | Expected                | Actual                           | Status  | Notes                                        |
|------------|-----------------------------------------|-------------------------|----------------------------------|---------|----------------------------------------------|
| QA-PAY-001 | Transfer with valid payload             | 200 with transactionRef | 401<br>MTLS_CERTIFICATE_REQUIRED | BLOCKED | mTLS enforced in sandbox — see ISSUE PEG-380 |
| QA-PAY-002 | Transfer with missing fields            | 422 Validation error    | 401<br>MTLS_CERTIFICATE_REQUIRED | BLOCKED | mTLS check runs before validation            |
| QA-PAY-003 | Transfer with invalid amount (negative) | 422 INVALID_AMOUNT      | 401<br>MTLS_CERTIFICATE_REQUIRED | BLOCKED | Cannot reach application layer               |

|            |                                         |                                |                                                                              |                  |                                             |
|------------|-----------------------------------------|--------------------------------|------------------------------------------------------------------------------|------------------|---------------------------------------------|
| QA-PAY-004 | Transfer with duplicate idempotency key | 200 with original response     | 401<br>MTLS_CERTIFICATE_REQUIRED                                             | BLOCKED          | Cannot test idempotency                     |
| QA-PAY-005 | Transfer exceeding daily limit          | 422<br>DAILY_LIMIT_EXCEEDED    | 401<br>MTLS_CERTIFICATE_REQUIRED                                             | BLOCKED          | Cannot test limit enforcement               |
| QA-PAY-006 | Intrabank transfer routing              | Routed internally (no MiServe) | Code review: destination bank code checked, intra vs inter routing confirmed | CODE REVIEW PASS | Avoids MiServe fees for same-bank transfers |
| QA-PAY-007 | Interbank transfer via MiServe          | Routed through MiServe gateway | Code review: MiServe client invoked with proper auth headers                 | CODE REVIEW PASS | MiServe timeout set to 30s                  |

### Transaction Status

| Test ID    | Test Case                       | Expected                                  | Actual                                                 | Status           | Notes                          |
|------------|---------------------------------|-------------------------------------------|--------------------------------------------------------|------------------|--------------------------------|
| QA-PAY-008 | Get status for valid reference  | 200 with transaction details              | 401<br>MTLS_CERTIFICATE_REQUIRED                       | BLOCKED          | mTLS enforced                  |
| QA-PAY-009 | Get status for non-existent ref | 404<br>TRANSACTION_NOT_FOUND              | 401<br>MTLS_CERTIFICATE_REQUIRED                       | BLOCKED          | Cannot reach application layer |
| QA-PAY-010 | Status response fields          | transactionRef, status, amount, timestamp | Code review: response DTO contains all required fields | CODE REVIEW PASS |                                |

### Name Enquiry

| Test ID    | Test Case                         | Expected                         | Actual                                     | Status           | Notes                          |
|------------|-----------------------------------|----------------------------------|--------------------------------------------|------------------|--------------------------------|
| QA-PAY-011 | Name enquiry with valid account   | 200 with accountName             | 401<br>MTLS_CERTIFICATE_REQUIRED           | BLOCKED          | mTLS enforced                  |
| QA-PAY-012 | Name enquiry with invalid account | 404<br>ACCOUNT_NOT_FOUND         | 401<br>MTLS_CERTIFICATE_REQUIRED           | BLOCKED          | Cannot reach application layer |
| QA-PAY-013 | Name enquiry field validation     | bankCode, accountNumber required | Code review: validation attributes present | CODE REVIEW PASS |                                |

### Bulk Transfer (New Feature)

| Test ID    | Test Case                              | Expected                    | Actual                                                                     | Status           | Notes         |
|------------|----------------------------------------|-----------------------------|----------------------------------------------------------------------------|------------------|---------------|
| QA-PAY-014 | Bulk transfer with valid payload       | 202 Accepted with batchRef  | 401 MTLS_CERTIFICATE_REQUIRED                                              | BLOCKED          | mTLS enforced |
| QA-PAY-015 | Bulk transfer max batch size           | Max 100 transfers per batch | Code review: batch size validated at 100                                   | CODE REVIEW PASS |               |
| QA-PAY-016 | Bulk transfer partial failure handling | Per-item status in response | Code review: each item processed independently, individual status returned | CODE REVIEW PASS |               |

### HMAC-SHA256 Signature (Code Review)

| Test ID    | Test Case                                   | Expected                        | Actual                                                            | Status           | Notes |
|------------|---------------------------------------------|---------------------------------|-------------------------------------------------------------------|------------------|-------|
| QA-PAY-017 | HMAC computed over request body + timestamp | Signature validated server-side | Code review: HmacAuthFilter validates signature before controller | CODE REVIEW PASS |       |
| QA-PAY-018 | HMAC with expired timestamp                 | 401 HMAC_EXPIRED                | Code review: 5-minute window enforced                             | CODE REVIEW PASS |       |

### MiServe Response Code Mapping (Code Review)

| Test ID    | Test Case                              | Expected          | Actual                                                                    | Status           | Notes |
|------------|----------------------------------------|-------------------|---------------------------------------------------------------------------|------------------|-------|
| QA-PAY-019 | MiServe code "00" → SUCCESS            | Maps correctly    | Code review: ResponseCodeMapper handles 35 MiServe codes                  | CODE REVIEW PASS |       |
| QA-PAY-020 | MiServe code "51" → INSUFFICIENT_FUNDS | Maps correctly    | Code review: mapped to 422 with clear error message                       | CODE REVIEW PASS |       |
| QA-PAY-021 | Unknown MiServe code → UNKNOWN_ERROR   | Graceful fallback | Code review: default case returns UNKNOWN_ERROR with original code logged | CODE REVIEW PASS |       |

### Issues Found

| ID      | Severity | Issue                                                                                                                                                                                                                                     | Status |
|---------|----------|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|--------|
| PEG-380 | Critical | All payment endpoints return 401 MTLS_CERTIFICATE_REQUIRED in sandbox — mTLS is enforced but no sandbox client certificate has been provisioned for QA or partner testing. This <b>blocks all functional testing</b> of the Payments API. | OPEN   |
| PEG-396 | Medium   | mTLS validation runs before HMAC and request validation — error messages are misleading when both are missing                                                                                                                             | OPEN   |
| PEG-397 | Low      | Bulk transfer endpoint not documented in OpenAPI spec                                                                                                                                                                                     | OPEN   |

## MiServe Response Code Reference (35 Codes)

| MiServe Code | Mapped Status                      | HTTP Code | Description                            |
|--------------|------------------------------------|-----------|----------------------------------------|
| 00           | SUCCESS                            | 200       | Transaction successful                 |
| 01           | REFER_TO_ISSUER                    | 422       | Refer to card issuer                   |
| 03           | INVALID_MERCHANT                   | 422       | Invalid merchant                       |
| 05           | DO_NOT_HONOR                       | 422       | Do not honor                           |
| 06           | ERROR                              | 500       | General error                          |
| 12           | INVALID_TRANSACTION                | 422       | Invalid transaction                    |
| 13           | INVALID_AMOUNT                     | 422       | Invalid amount                         |
| 14           | INVALID_ACCOUNT                    | 422       | Invalid card/account number            |
| 25           | RECORD_NOT_FOUND                   | 404       | Unable to locate record                |
| 30           | FORMAT_ERROR                       | 422       | Format error                           |
| 34           | SUSPECTED_FRAUD                    | 422       | Suspected fraud                        |
| 35           | CONTACT_ACQUIRER                   | 422       | Contact card acquirer                  |
| 38           | PIN_TRIES_EXCEEDED                 | 422       | Allowable PIN tries exceeded           |
| 39           | NO_CREDIT_ACCOUNT                  | 422       | No credit account                      |
| 40           | FUNCTION_NOT_SUPPORTED             | 422       | Requested function not supported       |
| 41           | LOST_CARD                          | 422       | Lost card — pick up                    |
| 43           | STOLEN_CARD                        | 422       | Stolen card — pick up                  |
| 51           | INSUFFICIENT_FUNDS                 | 422       | Insufficient funds                     |
| 52           | NO_CHECKING_ACCOUNT                | 422       | No checking account                    |
| 53           | NO_SAVINGS_ACCOUNT                 | 422       | No savings account                     |
| 54           | EXPIRED_CARD                       | 422       | Expired card                           |
| 55           | INCORRECT_PIN                      | 422       | Incorrect PIN                          |
| 56           | NO_CARD_RECORD                     | 422       | No card record                         |
| 57           | TRANSACTION_NOT_PERMITTED          | 422       | Transaction not permitted              |
| 58           | TRANSACTION_NOT_PERMITTED_TERMINAL | 422       | Transaction not permitted to terminal  |
| 61           | EXCEEDS_WITHDRAWAL_LIMIT           | 422       | Exceeds withdrawal amount limit        |
| 63           | SECURITY_VIOLATION                 | 422       | Security violation                     |
| 65           | EXCEEDS_FREQUENCY_LIMIT            | 422       | Exceeds withdrawal frequency limit     |
| 68           | RESPONSE_LATE                      | 504       | Response received too late             |
| 75           | PIN_TRIES_EXCEEDED                 | 422       | Allowable number of PIN tries exceeded |

|    |                       |     |                                             |
|----|-----------------------|-----|---------------------------------------------|
| 91 | ISSUER_UNAVAILABLE    | 503 | Issuer or switch inoperative                |
| 92 | ROUTING_ERROR         | 502 | Financial institution not found for routing |
| 94 | DUPLICATE_TRANSACTION | 409 | Duplicate transmission                      |
| 96 | SYSTEM_MALFUNCTION    | 500 | System malfunction                          |
| XX | UNKNOWN_ERROR         | 500 | Unmapped code — fallback                    |

## Recommendations

1. **CRITICAL:** Provision sandbox mTLS client certificates for QA and partner testing (PEG-380) — this is the single biggest blocker for Payments API validation
2. Consider disabling mTLS in sandbox environment and relying on HMAC + API key authentication only
3. Add bulk transfer endpoint to OpenAPI spec before partner documentation is published
4. Reorder middleware: validate HMAC before mTLS to provide clearer error messages
5. Add end-to-end payment flow tests once mTLS certificates are available